

REPORTE EJECUTIVO · CONSEJO DIRECTIVO

Red Team Report

Pentesting de My File Server 1

Evaluación de seguridad ofensiva sobre el servidor corporativo de archivos hallazgos, riesgo de negocio y plan de remediación.

PREPARADO PARA

Consejo Directivo: YukoCorp.

PREPARADO POR

LARZ· Red Team

FECHA

01/10/2026

CLASIFICACIÓN

Confidencial: Uso interno

Contexto del Engagement

El equipo de Red Team fue contratado para evaluar, mediante una prueba de penetración de caja negra, el nivel real de exposición del servidor de archivos corporativo simulado “My File Server: 1”, sin contar con credenciales ni conocimiento previo del entorno.

- Simular un atacante externo sin acceso previo
- Identificar vulnerabilidades explotables en servicios expuestos
- Medir el impacto real de negocio, no solo el técnico
- Entregar un plan de remediación priorizado

**Caja
negra**

Tipo de prueba

6.5 h

Duración del engagement

1

Activo en alcance

6

Hallazgos identificados

Metodología Aplicada (PTES)

Proceso estructurado y reproducible, alineado al Penetration Testing Execution Standard.



Resultado clave: en este engagement las seis fases se ejecutaron en secuencia continua, sin necesidad de fuerza bruta ni ingeniería social, hasta obtener control total (root) del sistema.

Nivel General del Riesgo

CALIFICACIÓN GLOBAL

CRÍTICO

Compromiso total del sistema (root) alcanzado sin explotación compleja ni credenciales previas.

< 30 min

de acceso anónimo a control root

6

Hallazgos totales

2

Severidad crítica

3

Severidad alta

1

Severidad baja

Hallazgos Críticos

CRÍTICA

Credenciales expuestas en el sitio web

Un archivo público del servidor (readme.txt) exponía usuario y contraseña válidos, punto de origen de toda la cadena de ataque.

H-01

CRÍTICA

Kernel vulnerable a DirtyCOW (CVE-2016-5195)

El sistema operativo, sin actualizar desde 2015, permitió escalar de un usuario limitado a control total (root).

H-02

ALTA

FTP anónimo con escritura habilitada

Permitió a un atacante sin credenciales subir archivos arbitrarios al servidor, incluida una llave de acceso SSH.

H-03

Escenario de Impacto Empresarial

¿Qué pasaría si este servidor fuera productivo y el atacante fuera real?



Confidencialidad

Acceso root permite leer cualquier documento, contrato o dato de clientes almacenado en el servidor.



Integridad

Los archivos y configuraciones pueden ser modificados o sustituidos sin dejar rastro visible para el usuario final.



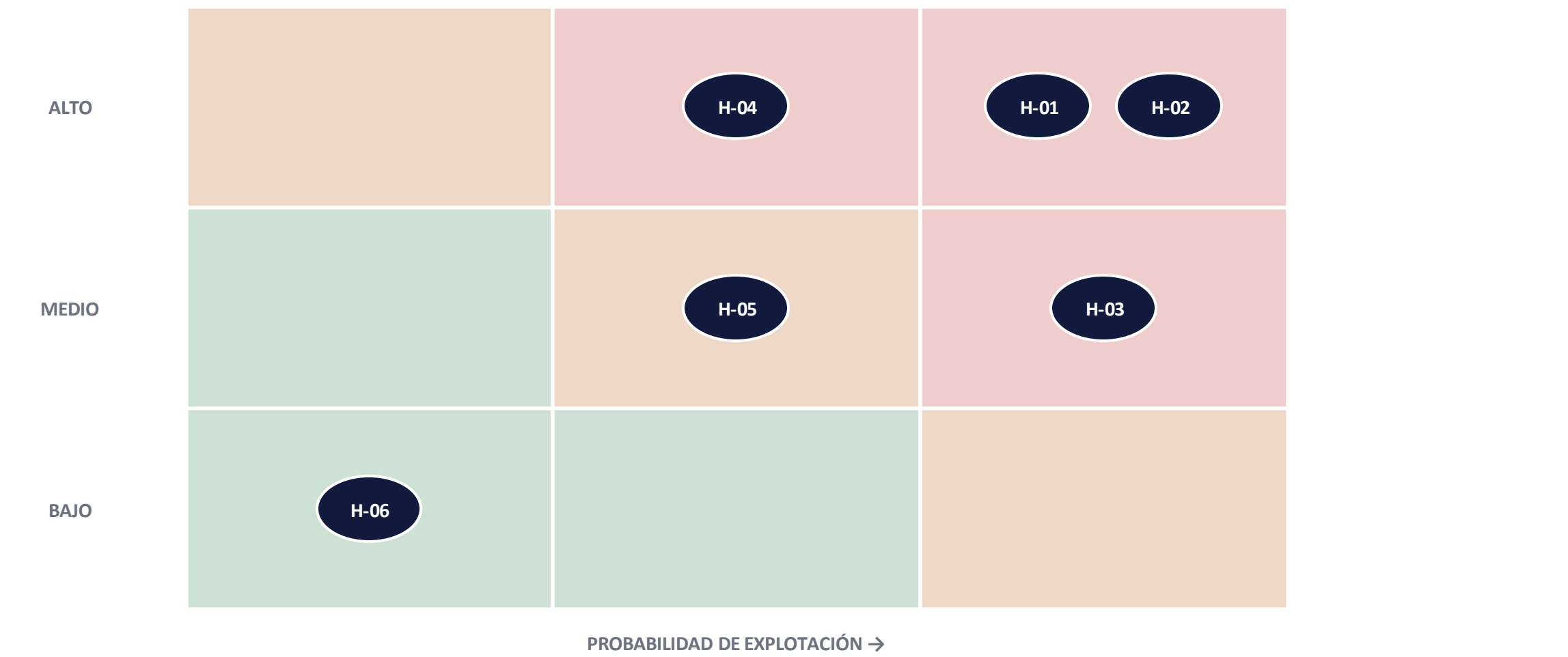
Disponibilidad

Con control total, un atacante podría eliminar información o desplegar ransomware, deteniendo la operación.

Además del daño operativo, un incidente de este tipo implica riesgo reputacional y posible exposición legal/regulatoria por fuga de datos.

Matriz de Riesgo

Hallazgos ubicados según su probabilidad de explotación e impacto en el negocio.



Recomendaciones Estratégicas

Inmediato

- Parchar el kernel vulnerable
- Retirar credenciales expuestas del sitio web
- Deshabilitar el login anónimo en FTP

Corto plazo

- Endurecer permisos de recursos SMB
- Rotar y fortalecer contraseñas de servicio
- Aislar el servicio FTP del sistema de archivos

Mediano / largo plazo

- Programa formal de gestión de vulnerabilidades
- Monitoreo centralizado (SIEM)
- Hardening continuo (CIS Benchmarks)

Roadmap de Remediación

0–15 días

Remediación crítica

15–30 días

Endurecimiento

30–90 días

Madurez continua

Parchado de kernel y retiro de credenciales expuestas

Permisos SMB/FTP, rotación de credenciales, TRACE off

Gestión de vulnerabilidades, SIEM, hardening CIS

CONCLUSIÓN EJECUTIVA

Configuraciones básicas mal aplicadas bastaron para comprometer por completo el servidor.

No se requirió una vulnerabilidad exótica ni un ataque sofisticado: acceso anónimo, una contraseña publicada por error y un kernel sin actualizar fueron suficientes para escalar de cero a control total (root). La inversión en los controles básicos recomendados reduce drásticamente esta superficie de ataque.

- **Aprobar** el plan de remediación de 90 días
- **Asignar** presupuesto y responsable de seguimiento
- **Programar** una reevaluación posterior a la remediación